Da declaração à verificação: proteção de dados verificável em um aplicativo de acompanhamento menstrual

Millene Santos e Silva, Edgard Afonso Lamounier Junior
{millene12111qido32, lamounier}@ufu.br

XX Workshop de Teses e Dissertações em Ciência da Computação
2026

RESUMO

Aplicativos de ciclo menstrual guardam dados sensíveis, mas costumam apenas declarar que os protegem. Este trabalho propõe quatro verificações reprodutíveis e as aplica ao Luna, aplicativo Android de código aberto com backend auto-hospedável. Os testes confirmaram controle de acesso, isolamento entre contas, nenhuma credencial exposta e nenhum rastreador de terceiros.

INTRODUÇÃO

Aplicativos de acompanhamento menstrual registram datas, sintomas, humor e atividade sexual. A LGPD (Lei 13.709/2018) classifica dados de saúde e de vida sexual como sensíveis.

Mesmo assim, análises de aplicativos Android de saúde encontraram rastreadores de terceiros na maioria dos casos. Alternativas de código aberto evitam isso guardando tudo só no celular, o que impede o uso em vários dispositivos e a hospedagem por instituições de saúde.

Pergunta: como mostrar, ainda durante o desenvolvimento, que um aplicativo protege esses dados, em vez de só afirmar isso na política de privacidade?

Objetivo: definir verificações reprodutíveis que transformem promessas de privacidade em propriedades checáveis no código, aplicá-las ao Luna e deixar claro o que elas ainda não cobrem.

MATERIAIS E MÉTODOS

O Luna usa arquitetura cliente-servidor: aplicativo Android em Kotlin e servidor em Python (FastAPI), sob licença GNU GPL v3. Foram definidas quatro verificações:

1. **Controle de acesso:** cada endpoint protegido é chamado sem token e com token inválido ou expirado.
2. **Isolamento entre contas:** uma usuária autenticada tenta ler, alterar e remover registros de outra.
3. **Exposição de credenciais:** os esquemas de resposta da API são varridos em busca de senhas ou hashes.
4. **Destinos de rede:** inspeção estática das dependências e dos endereços configurados no aplicativo e no backend.

As três primeiras rodam no backend. Código e testes são abertos para qualquer pessoa reexecutar.

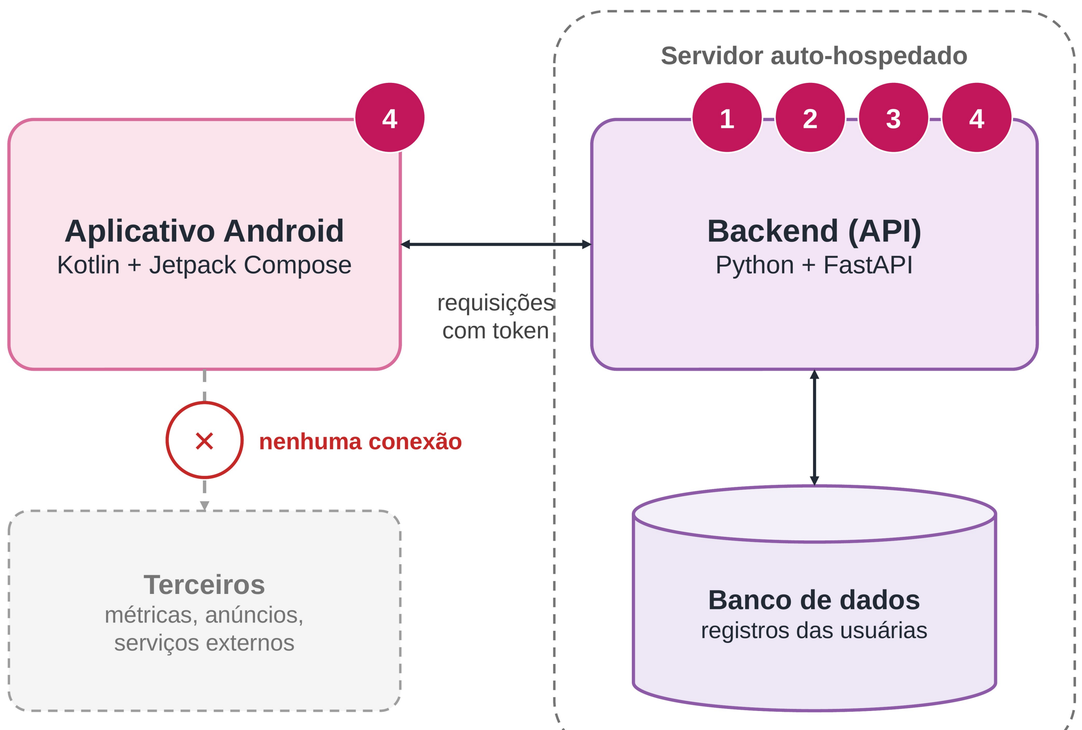


Figura 1. *Arquitetura do Luna. Os círculos numerados indicam onde atua cada verificação.*

RESULTADOS ESPERADOS

O backend tem **150 testes automatizados aprovados** e **94% de cobertura de linhas**. As quatro verificações passaram:

Verificação	Resultado no Luna
1. Controle de acesso	17 de 17 endpoints protegidos recusam (401) token ausente, inválido ou expirado.
2. Isolamento entre contas	Registro de outra usuária retorna 404; o identificador enviado pelo app é ignorado.
3. Exposição de credenciais	Nenhuma resposta da API contém senha, hash ou chave de assinatura.
4. Destinos de rede	Nenhuma biblioteca de análise, anúncios ou backend como serviço; único destino: o próprio backend.

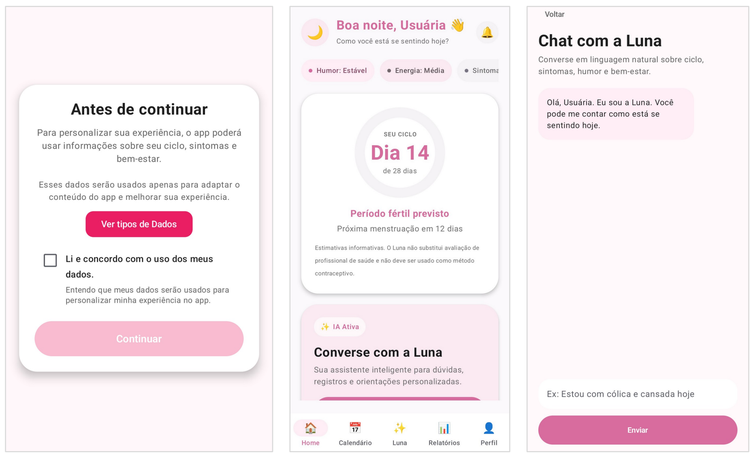


Figura 2. *Telas do Luna: consentimento, tela inicial e conversa com a assistente.*

LIMITAÇÕES

- **Rede só estática:** o tráfego real do app em um aparelho ainda não foi capturado.
- **Consentimento antes do login:** a tela já envia o aceite, mas, sem sessão ativa, o servidor o recusa (401).
- **Logs detalhados:** o cliente HTTP grava no log do Android o corpo das requisições, inclusive senha e token.
- **LGPD incompleta:** não há exclusão de conta nem exportação dos dados (art. 18), só a remoção de registros isolados.
- **Implantação:** em desenvolvimento o tráfego usa HTTP e o banco não é cifrado; TLS e criptografia em repouso dependem de quem hospeda.
- **Escopo:** testes mostram a presença de falhas, não a ausência; o Android não tem testes próprios e não houve avaliação com usuárias.

CONCLUSÕES

No Luna, a proteção de dados pôde ser **verificada**, e não apenas declarada: quatro promessas típicas de políticas de privacidade viraram testes automatizados que qualquer pessoa reexecuta a partir do código aberto.

Verificar também revelou **o que falta**, como os logs detalhados e a falta de exclusão de conta, algo que uma política de privacidade não mostraria. As verificações independem do domínio e servem a outros aplicativos de saúde com backend próprio.

Próximos passos: análise dinâmica do tráfego, consentimento registrado após o login, logs só em modo de depuração, exclusão e exportação de dados, testes no Android e avaliação com usuárias.

BIBLIOGRAFIA

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD).

TANGARI, G. et al. Mobile health and privacy: cross sectional study. BMJ, v. 373, n1248, 2021.

SHIPP, L.; BLASCO, J. How private is your period? A systematic analysis of menstrual app privacy policies. Proceedings on Privacy Enhancing Technologies, v. 2020, n. 4, p. 491-510, 2020.

AGRADECIMENTOS

À FAPEMIG, pela bolsa de Iniciação Científica, e à Pró-Reitoria de Pesquisa e Pós-Graduação (PROPP/UFU).